

REGELN FÜR DIE DURCHFÜHRUNG VON PENETRATIONSTESTS

1. Zweck dieses Dokuments

Dieses Dokument definiert die operativen Regeln und Rahmenbedingungen für die Durchführung von Cybersecurity-Tests durch **Robert Richards Cybersecurity**.

Die Regeln ergänzen den **Dienstleistungsvertrag** sowie das **Autorisierungsschreiben** zwischen dem Kunden und Robert Richards Cybersecurity.

Ziel ist die Durchführung eines kontrollierten, sicheren und rechtlich autorisierten Sicherheitstests.

2. Projektübersicht

Kunde: _____

Dienstleister: Robert Richards Cybersecurity

Projektbezeichnung: _____

Projektverantwortlicher (Kunde): _____

Projektverantwortlicher (Tester): Robert Richards

Startdatum: _____

Enddatum: _____

Testzeitfenster: 06:00 - 22:00

3. Autorisierter Testumfang

Tests werden ausschließlich auf den ausdrücklich freigegebenen Systemen durchgeführt.

Domains

IP-Adressbereiche

Anwendungen

APIs / Dienste

Cloud-Infrastruktur

4. Systeme außerhalb des Scopes

Folgende Systeme dürfen **nicht** getestet werden:

5. Testmethoden

Mögliche Testmethoden umfassen:

- automatisierte Schwachstellenscans
- manuelle Penetrationstests
- Tests von Authentifizierungsmechanismen
- Netzwerkanalyse und Enumeration
- Sicherheitsanalysen von Web-Anwendungen und APIs
- Konfigurationsanalyse
- Ausnutzung von Schwachstellen zu Demonstrationszwecken

Die Tests orientieren sich an anerkannten Industriestandards, u. a.:

- OWASP Testing Guide
- NIST SP 800-115
- PTES (Penetration Testing Execution Standard)

6. Verbotene Aktivitäten

Ohne ausdrückliche schriftliche Genehmigung des Kunden sind folgende Aktivitäten untersagt:

- Denial-of-Service-Tests
- Zerstörerische Exploits
- absichtliche Datenlöschung
- Veränderung von Produktionsdaten
- Social-Engineering-Angriffe
- Phishing-Kampagnen
- physische Sicherheitstests

7. Quell-IP-Adressen des Testers

Der Testverkehr kann von folgenden IP-Adressen ausgehen:

Diese IP-Adressen sollten gegebenenfalls auf die Zulassungsliste gesetzt werden.

8. Testzeitraum

Tests werden im folgenden Zeitraum durchgeführt:

06:00 - 22:00

Risikoreiche Tests können außerhalb der regulären Geschäftszeiten stattfinden.

9. Kommunikationskontakte

Hauptansprechpartner (Kunde)

Name: _____

Position: _____

Telefon: _____

E-Mail: _____

Technischer Ansprechpartner (Kunde)

Name: _____

Position: _____

Telefon: _____

E-Mail: _____

Tester

Robert Richards
Robert Richards Cybersecurity

E-Mail: robert.k.richards@gmail.com

Telefon: 01782689662

10. Umgang mit Zwischenfällen

Sollte es während der Tests zu unerwarteten Systemstörungen kommen:

1. wird der Test sofort unterbrochen
2. wird der Ansprechpartner des Kunden informiert
3. wird der Test erst nach Freigabe durch den Kunden fortgesetzt

11. Umgang mit Daten

Während der Tests können begrenzte Daten zur Dokumentation von Schwachstellen erhoben werden.

Beispiele:

- Screenshots
- Systemkonfigurationen
- Exploit-Nachweise

Es werden **nur die minimal notwendigen Daten erhoben**, um die Schwachstelle zu belegen.

12. Überwachungssysteme

Der Kunde erkennt an, dass die Tests Sicherheitsalarme auslösen können, beispielsweise in:

- SIEM-Systemen
- IDS/IPS-Systemen
- Endpoint-Security-Systemen
- Netzwerküberwachungssystemen

13. Rechtliche Grundlage

Die Tests erfolgen mit ausdrücklicher Genehmigung des Kunden.

Diese Autorisierung ist insbesondere relevant im Zusammenhang mit folgenden Vorschriften des deutschen Strafgesetzbuchs:

- Strafgesetzbuch §202a
- Strafgesetzbuch §202b
- Strafgesetzbuch §303a
- Strafgesetzbuch §303b

Der Kunde bestätigt, dass er zur Autorisierung dieser Tests berechtigt ist.

14. Berichtswesen

Nach Abschluss der Tests erhält der Kunde einen Sicherheitsbericht mit:

- Management-Zusammenfassung
- Beschreibung der Schwachstellen
- Risikobewertung
- Handlungsempfehlungen

15. Vertraulichkeit

Alle während des Tests identifizierten Informationen und Schwachstellen werden vertraulich behandelt.

16. Zustimmung

Durch ihre Unterschrift bestätigen beide Parteien die Einhaltung dieser Regeln.

Dienstleister

Robert Richards Cybersecurity

Name: Robert Richards

Ort: Karlsruhe, Germany

Datum: 01/01/2026

Unterschrift: _____

Kunde

Name: _____

Organisation: _____

Position: _____

Ort: _____

Datum: _____

Unterschrift: _____